

BỘ GIÁO DỤC VÀ ĐÀO TẠO — KHOA CÔNG NGHỆ THÔNG TIN
ĐỀ CƯƠNG CHI TIẾT ĐỒ ÁN TỐT NGHIỆP ĐẠI HỌC CHÍNH QUY

XÂY DỰNG CƠ CHẾ POLICY DECISION POINT HỖ TRỢ ỦY QUYỀN CÓ KIỂM SOÁT
(DELEGATION-AWARE AUTHORIZATION) CHO TÁC TỬ AI TRONG HỆ THỐNG ERP —
NGHIÊN CỨU TRIỂN KHAI VÀ ĐÁNH GIÁ THỰC NGHIỆM TRÊN NỀN TẢNG ODOO

Design and Implementation of a Delegation-Aware Policy Decision Point for Autonomous AI Agents in ERP Systems — An Empirical Evaluation on the Odoo Platform

Chuyên ngành: Kỹ thuật Phần mềm (Software Engineering)	Loại hình: Nghiên cứu Ứng dụng & Phát triển Hệ thống Phân tán
Sinh viên thực hiện:	MSSV: — Lớp:
Cán bộ hướng dẫn:	Thời gian thực hiện: 16 tuần (Học kỳ tốt nghiệp)
Mục tiêu hiệu năng: In-Memory Core 27ns E2E gRPC < 1ms	Kiến trúc: NIST SP 800-162, Zero Trust, NIST AI RMF

TRỰC TIẾN HÓA NGHIÊN CỨU TAM ĐOẠN LUẬN (RESEARCH LINEAGE)

- HIGH-PERFORMANCE PDP (GỐC RỄ KỸ THUẬT PHẦN MỀM - BASELINE PROTOTYPE): Động cơ In-Memory Go Core, Trie FNV-1a uint64, Role DAG Transitive Closure O(1), Copy-On-Write Lock-Free, Zero Heap Allocation (27ns).
- ENTERPRISE AUTHORIZATION (MIỀN THỰC NGHIỆM KIỂM CHỨNG - VALIDATION): Mô hình 4-Tuple NIST SP 800-162 giải quyết Role Explosion và kiểm soát Phân tách trách nhiệm (SoD theo SOX 404) trên Odoo 17.
- DELEGATION-AWARE AI AUTHORIZATION (TRỌNG TÂM NGHIÊN CỨU MỚI - RESEARCH FOCUS): Chuỗi ủy quyền 1-Hop, Bất biến suy giảm quyền lực theo thời gian, chống TOCTOU bằng In-Memory Revocation O(1), và Rào chắn tiền định 3 trạng thái (ALLOW / DENY / REQUIRE_APPROVAL) theo NIST AI RMF & OWASP LLM06.

I. Bốn Câu Hỏi Nghiên Cứu Cốt Lõi (Core Research Questions)

- RQ1 (Mô hình hóa Định danh & Chuỗi Ủy Quyền Tác tử AI):** Làm thế nào để xây dựng mô hình định danh hợp nhất (Unified Authorization Subject) và bộ ngũ ủy quyền có kiểm soát Δ biểu diễn chính xác quan hệ Người ủy quyền (Delegator) -> AI Agent (Delegatee) và ràng buộc thời gian thực?
- RQ2 (Hiệu Năng Runtime & Tối Ưu Bộ Nhớ Cấp Máy):** Làm thế nào để thiết kế một Động cơ In-Memory đạt độ trễ đánh giá nano-giây (27ns), thông lượng trên 30.000.000 decisions/giây và triệt tiêu heap allocation trên hot-path đánh giá?
- RQ3 (Cơ Chế Kiểm Soát Rủi Ro & An Toàn Tiền Định):** Làm thế nào cơ chế quyết định 3 trạng thái (ALLOW / DENY / REQUIRE_APPROVAL) hạn chế tác động rủi ro (Impact Mitigation) khi tác tử AI bị ảo giác hoặc bị tấn công Prompt Injection?
- RQ4 (Đánh Giá Thực Nghiệm & So Sánh Đa Chiều Trên Odoo):** Động cơ đề xuất thể hiện tính đúng đắn chức năng (Functional), độ an toàn bảo mật (Security), và hiệu năng mở rộng (Performance) như thế nào trên miền doanh nghiệp Odoo ERP so với cơ chế Record Rules truyền thống?

II. Tính Cấp Thiết & Khoảng Trống Nghiên Cứu (Problem Statement & Research Gap)

- Bối cảnh Doanh nghiệp Tự hành (Autonomous Enterprise):** Tỷ trọng ngày càng lớn các giao dịch tài chính, mua hàng và đối soát kế toán sẽ được khởi tạo hoặc thực hiện tự động bởi các Tác tử AI qua các lệnh gọi công cụ (Tool-Calls).
- Khủng hoảng của RBAC & Hiểm họa rủi ro AI:** RBAC gây bùng nổ hàng nghìn vai trò tĩnh và rò rỉ logic vào SQL. Đồng thời, AI là mô hình xác suất có rủi ro ảo giác (Hallucination) hoặc bị lừa (Prompt Injection) ra lệnh chi tiền trái phép. Động cơ PDP đóng vai trò là chốt chặn tiền định cô lập và hạn chế tối đa tác động rủi ro (Impact Mitigation).
- Bài toán nghiên cứu duy nhất:** Thiết kế một Runtime phân quyền chuyên biệt độ trễ thấp (Specialized Low-Latency Authorization Runtime) trong bộ nhớ RAM, tách rời hoàn toàn logic kiểm tra quyền ra khỏi ứng dụng.

III. Tổng Quan Tình Hình Nghiên Cứu Liên Quan (Literature Review)

- Mô hình toán học & Chuẩn quốc tế:** NIST SP 800-162 (Vincent Hu et al.) đặc tả cấu trúc PEP-PDP-PIP-PAP; OASIS XACML v3.0 quy định thuật toán kết hợp quyết định Deny-by-Default và Forbid-Overrides; NIST SP 800-207 Zero Trust Architecture.

- Ngôn ngữ chính sách & An toàn AI:** AWS Cedar Language (ACM OOPSLA 2024) về phân tích hình thức và giới hạn độ sâu AST chống DoS; Google Zanzibar (USENIX ATC 2019) về xử lý phân quyền đồ thị; NIST AI RMF 1.0 và OWASP LLM06 Excessive Agency.
- Thuật toán hiệu năng cao:** Radix Trie FNV-1a và Role DAG Transitive Closure chuyển hóa việc kiểm tra kế thừa sang $O(1)$ query; Copy-On-Write (COW) với atomic.Pointer đảm bảo đọc lock-free 100%.

IV. Mục Tiêu & Ranh Giới Nghiên Cứu (Foundation vs. Thesis Scope)

A. NỀN TẢNG KẾ THỪA (EXISTING FOUNDATION)	B. PHẠM VI ĐÓNG GÓP MỚI (THESIS SCOPE)
• Động cơ In-Memory Go Core & Pratt Parser	• Chuẩn hóa Input 4-Tuple NIST và Bộ ngữ Ủy quyền Δ (RQ1)
• Cấu trúc chỉ mục Trie FNV-1a & Role DAG Closure	• Đánh giá chuỗi ủy quyền 1-Hop & Suy giảm quyền lực theo thời gian
• Copy-On-Write Lock-Free & gRPC JSON Server	• Triệt tiêu TOCTOU bằng In-Memory Revocation Blacklist $O(1)$
• Đồng bộ Postgres Monotonic Seq & WORM Logger	• Rào chắn tiền định 3 trạng thái & Lộ trình 2 pha cho Obligations

V. Phương Pháp Nghiên Cứu & Dự Kiến Đóng Góp Kỹ Thuật

- Mô Hình Phân Quyền Ủy Quyền Cho Tác Từ AI (Delegation-Aware Agent Authorization):** Hình thức hóa bộ ngữ ủy quyền Δ và bảo toàn tính suy giảm quyền lực theo thời gian: $P_{\text{effective}}(A|U, t) = P_{\text{active}}(U, t) \cap S_{\text{delegation}} \cap \Omega_{\text{guardrails}}$.
- Kiến Trúc Phân Tầng An Ninh & Lỗi Đánh Giá 27ns:** Tầng 1 Security Interceptor xác thực mTLS, verify HMAC delegation_proof và tra cứu Revocation Map $O(1)$. Tầng 2 Hot-path In-Memory Core thực thi logic phân quyền thuần túy với 0 allocs/op.
- Bảo Toàn Phân Tách Trách Nhiệm Tổng Quát (Generalized SoD):** Cấm người tạo đơn duyệt đơn thông qua toán tử contains trên chuỗi phân tách bởi dấu phẩy (context.delegation_chain contains resource.creator_id).

VI. Kế Hoạch Thực Hiện & Tiến Độ 16 Tuần

Giai Đoạn	Nội Dung Công Việc Chi Tiết	Thời Gian	Sản Phẩm Đầu Ra
Giai đoạn 1	Khảo sát lý thuyết NIST SP 800-162, đặc tả mô hình Unified Subject, Delegation Chain & Threat Model giải quyết RQ1, RQ3	Tuần 1 - 3	Báo cáo SRS & Đặc tả mô hình
Giai đoạn 2	Kế thừa Foundation Engine, mở rộng Pratt Parser & AST Compiler hỗ trợ Delegation & Tool Context	Tuần 4 - 7	Bộ thư viện cú pháp mở rộng
Giai đoạn 3	Hiện thực hóa Risk-Aware Tri-State Engine (REQUIRE_APPROVAL) và cơ chế Human-in-the-Loop giải quyết RQ2, RQ3	Tuần 8 - 11	Mã nguồn Go PDP mở rộng
Giai đoạn 4	Tích hợp thử nghiệm trên 4 kịch bản Enterprise ERP và mô phỏng Multi-Agent Workflows	Tuần 12 - 13	Hệ thống phân tán & Module ERP
Giai đoạn 5	Thực nghiệm toàn diện 3 chiều (Functional, Security, Performance) giải quyết RQ4, hoàn thiện thuyết minh 100 trang	Tuần 14 - 16	Thuyết minh đồ án 100 trang

VII. Khung Đánh Giá Thực Nghiệm 3 Chiều & Kết Quả Đạt Được

- 1. Functional Evaluation (Tính Đúng Dẫn Chức Năng):** Kiểm chứng 100% PASS 7 kịch bản ERP P2P thực tế (PO limits, Generalized SoD, Chi nhánh, Lương) và chuỗi ủy quyền Tool-Call của AI Agent.

- **2. Security Evaluation (An Toàn Bảo Mật & Threat Model):** Kiểm thử khả năng chống leo thang đặc quyền, chặn đứng Prompt Injection (\$10M) trong 286.3 ns theo chuẩn NIST/OWASP LLM06, và triệt tiêu hoàn toàn TOCTOU qua In-Memory Revocation Blacklist $O(1)$ trong $< 1 \mu s$.
- **3. Performance Evaluation (Kết Quả Đo Tài Thực Tế Trên 20 Cores CPU):** Thông lượng đánh giá đồng thời: $\sim 36.800.000$ decisions/s (27.12 ns/op); Tải 10.000 Policies đồng thời: $\sim 27.800.000$ decisions/s (35.94 ns/op); 0 byte heap allocation trên hot-path.

VIII. Bố Cục Dự Kiến Của Luận Văn Thuyết Minh (5 Chương)

- **Chương 1:** Giới thiệu tổng quan, Bối cảnh Doanh nghiệp Tự hành, Đặt vấn đề và 4 câu hỏi nghiên cứu (RQ1–RQ4).
- **Chương 2:** Cơ sở lý thuyết & Mô hình phân quyền ABAC/PBAC (NIST SP 800-162), Chuẩn an toàn AI (NIST AI RMF, OWASP LLM06) và Lý thuyết Ủy quyền có kiểm soát.
- **Chương 3:** Thiết kế kiến trúc phân tầng (Security Interceptor vs In-Memory Core 27ns), Giải thuật Radix Trie FNV-1a, Role DAG Transitive Closure $O(1)$, và Lộ trình 2 pha cho Obligations.
- **Chương 4:** Hiện thực hóa & Tích hợp vào hệ thống ERP thực tế: Custom Module Odoo 17 (pdp_authorizer), chuỗi ủy quyền ngăn cách dấu phẩy, và toán tử SoD contains (evaluator.go:387).
- **Chương 5:** Đánh giá thực nghiệm 3 chiều (Functional - Security - Comparative Performance), Kết luận & Hướng phát triển mở rộng.

IX. Danh Mục Tài Liệu Tham Khảo Học Thuật (IEEE References)

[1] V. C. Hu, D. Ferraiolo, R. Kuhn et al., 'Guide to Attribute Based Access Control (ABAC) Definition and Considerations', NIST Special Publication 800-162, 2014.

[2] S. Rose, O. Borchert, S. Mitchell, and S. Connelly, 'Zero Trust Architecture', NIST Special Publication 800-207, 2020.

[3] National Institute of Standards and Technology (NIST), 'Artificial Intelligence Risk Management Framework (AI RMF 1.0)', NIST Trustworthy and Responsible AI, 2023.

[4] OWASP Foundation, 'OWASP Top 10 for Large Language Model Applications (LLM06: Excessive Agency)', OWASP GenAI Security Project, 2023.

[5] OASIS Standard, 'eXtensible Access Control Markup Language (XACML) Version 3.0', OASIS Open, 2013.

[6] B. Cook, M. Disenfeld, M. Eilers et al. (AWS Research), 'Cedar: A New Language for Expressive, Fast, Safe, and Analyzable Authorization', Proc. ACM Program. Lang., ACM OOPSLA 2024.

[7] R. Pang, P. Bisht, A. Cidon, and R. Stutsman (Google Research), 'Zanzibar: Google's Consistent, Global Authorization System', in USENIX ATC '19, pp. 907-920, 2019.

[8] D. F. Ferraiolo, R. Sandhu et al., 'Proposed NIST standard for role-based access control', ACM TISSEC, vol. 4, no. 3, pp. 224-274, 2001.

[9] Gartner Research, 'Market Guide for Policy-Based Access Control and Externalized Runtime Authorization for Modern Workloads and AI Agents', Gartner Inc., 2024.

[10] United States Congress, 'Sarbanes-Oxley Act of 2002 (SOX)', Section 404: Management Assessment of Internal Controls, 2002.

[11] ISO/IEC, 'ISO/IEC 27001:2022 Information Security Management Systems — Requirements', International Organization for Standardization, 2022.

[12] SAP SE & Odoo S.A., 'Enterprise Security Framework, Access Control & Record Rules Documentation', 2024.

CÁN BỘ HƯỚNG DẪN
(Ký và ghi rõ họ tên)

Ngày tháng năm 202...

TRƯỜNG BỘ MÔN KỸ THUẬT PHẦN MỀM
(Ký và ghi rõ họ tên)

Ngày tháng năm 202...